Vulnerability Assessment & Penetration Testing

Prepared By : Aditya Mehta

Date : 20th March, 2026

Introduction :

- This report presents the findings of a Vulnerability Assessment and Penetration Testing (VAPT) performed on a target system hosted in a controlled lab environment.
- The objective was to identify security weaknesses, exploit vulnerabilities, and provide remediation recommendations.
- While this technological advancement enhances efficiency and accessibility, it also introduces a wide range of security risks.
- Cyber threats such as unauthorized access, data breaches, and system exploitation can have severe financial, operational, and reputational consequences.
- Therefore, it is essential to proactively identify and mitigate vulnerabilities within systems before they can be exploited by malicious actors.
- This report documents a comprehensive VAPT assessment conducted on a deliberately vulnerable system hosted in a controlled lab environment.
- The ultimate goal is to provide a clear understanding of the system's security weaknesses and to assist in strengthening its overall security.

Objectives :

- Identify vulnerabilities using scanning tools.
- Perform structured penetration testing.
- Validate vulnerabilities through exploitation.
- Conduct post-exploitation activities.
- Assign CVSS scores for risk prioritization.
- Provide remediation recommendations.

Scope :

Parameter	Value
Target IP	192.168.56.101
Environment	Local Virtual Lab
Testing Type	Black-Box
Attacker Machine	Kali Linux

Tools Used :

- Nmap
- Nikto
- Metasploit Framework
- Netcat
- Browser (for web testing)
- Recon

Methodology (PTES) :

- The assessment followed PTES phases :
    1. Reconnaissance
    2. Scanning
    3. Exploitation
    4. Post-Exploitation
    5. Reporting

Vulnerability Scanning Techniques :

Core Concepts :

- **Network Scanning :** Identifies open ports using tools like Nmap.
- **Authenticated vs Unauthenticated Scans :**
    — Authenticated – deeper analysis
    — Unauthenticated – external attacker view
- **Application Scanning :** Detects web vulnerabilities using Nikto

Vulnerability Scoring :

- Based on CVSS v4.0
- Example : RCE – Score 8.8+ (High/Critical)
- **Base, Temporal and Environmental Metrics** :
    — CVSS scoring considers multiple factors such as exploitability, impact, and environmental conditions to provide a more accurate risk rating.

- **Prioritization od Remediation Efforts :**
  - Higher CVSS scores (e.g., 9.0–10.0) indicate critical vulnerabilities that must be addressed immediately, helping security teams prioritize fixes efficiently.
- **Standardization Risk Communication :**
  - CVSS provides a universal scoring system that helps teams and stakeholders clearly understand and communicate the severity of vulnerabilities.

False Positives :

- Validated Manually (e.g., confirming open ports via service interaction)
- **Cross – Verification Using Multiple Tools :**
  - Results from one tool (e.g., Nmap) should be verified using another tool or technique (such as manual service interaction or a different scanner) to confirm the accuracy of the detected vulnerability.
- **Context – Based Validation :**
  - Not all detected vulnerabilities are exploitable in real-world scenarios.
  - Factors such as network configuration, authentication requirements, and system permissions must be analyzed to determine whether the vulnerability poses an actual risk.
- **Service Interaction Testing :**
  - Directly interacting with the service (e.g., FTP login, HTTP request testing) helps confirm whether the reported vulnerability is truly present or just a misinterpretation by the scanning tool.

Penetration Testing Techniques :

Phases :

- Reconnaissance.
- Scanning.
- Exploitation.
- Post-Exploitation.
- Reporting.

Methodologies :

- PTES.
- OWASP WSTG.

Ethics :

- Testing performed in controlled lab.
- No unauthorized systems targeted.

Exploit Development Basics :

Types :

- **SQL Injection :**
  - — SQL Injection is a web application vulnerability that occurs when user input is not properly validated or sanitized before being included in SQL queries.
  - — Attackers can manipulate input fields (such as login forms or URL parameters) to execute malicious SQL commands on the database.
  - — **Impact :** High — can lead to complete database compromise.
  - — **Major Risk :** Bypass authentication, Modify or Delete records.

- **XSS :**
  - — XSS is also known as **Cross – Site Scripting.**
  - — Cross-Site Scripting (XSS) is a client-side vulnerability where malicious scripts are injected into web pages viewed by other users.
  - — This occurs when user input is not properly escaped or validated.
  - — **Impact :** Medium to High — depending on user privileges.
  - — **Major Risk :** Stolen session cookies, perform actions on behalf of users, Redirect users to malicious websites.
- **Buffer Overflow :**
  - — A buffer overflow occurs when a program writes more data to a memory buffer than it can handle, causing adjacent memory to be overwritten.
  - — This typically happens in low-level languages like C or C++ where memory management is manual.
  - — **Impact :** Critical — can lead to full system compromise (RCE).
  - — **Major Risk :** Crash the system, Execute arbitrary code, Gain unauthorized access.

Concepts :

- Exploits developed using PoC references.
- Understanding mitigations like ASLR and Patching.
- Payload Generation.
- Exploit reliability & stability.
- Privilege Escalation.

Reconnaissance :

Recon Activity Log :

Timestamp	Tool	Finding
2026-03-17 08:41	Nmap	Host is live
2026-03-17 08:43	Nmap	Open ports discovered
2026-03-17 08:47	Nmap	Services identified
2026-03-17 10:57	Nikto	Web vulnerabilities found

Domain Information :

- Target IP : 192.168.56.101
- Hostname : metasploitable.localdomain
- WHOIS : Not applicable (Internal system)

Technology Stack :

- Apache 2.2.8
- PHP 5.2.4
- MySQL 5.0.51
- Samba 3.0.20
- vsftpd 2.3.4

Exposed Services :

Port	Service	Risk
21	FTP	High
23	Telnet	High
80	HTTP	High
445	SMB	Medium
3306	MySQL	High

Recon Summary (50 words) :

- The reconnaissance phase identified the target as a vulnerable Linux-based system in a controlled lab environment.
- Multiple exposed services including FTP, HTTP, and SMB were discovered.
- Outdated software versions and insecure configurations significantly increased the attack surface, making the system highly vulnerable to exploitation and unauthorized access.

Vulnerability Scanning :

Nmap Findings :

- Multiple open ports.
- Outdated services.
- Weak configurations.

- Presence of insecure remote services.
- Detection of legacy and vulnerable software versions.

Nikto Findings :

- Missing security headers.
- Directory indexing.
- phpinfo exposed.
- Outdated Apache.

Scan ID	Vulnerability	CVSS	Priority	Host
001	vsftpd Backdoor	9.8	Critical	192.168.56.101
002	Apache Outdated	7.5	High	192.168.56.101
003	Telnet Enabled	7.0	High	192.168.56.101
004	SMB Signing Disabled	6.5	Medium	192.168.56.101
005	Directory Listing	5.3	Medium	192.168.56.101
006	Missing Security Headers	4.3	Low	192.168.56.101

Exploit Log :

Exploit ID	Description	Target IP	Status	Payload
001	Bind Shell Access	192.168.56.101	Success	Netcat

Exploit Details :

- **Command Used :** nc 192.168.56.101 1524
- **Result :** Root access obtained.

Post – Exploitation :

Actions Performed :

- Verified root access.
- Navigated file system.
- Extracted sensitive data.

Evidence Collection :

Item	Description	Date	Hash
Nmap Scan	Open ports & services	2026-03-18	N/A
Nikto Scan	Web vulnerabilities	2026-03-18	N/A
Root Access	Root shell obtained	2026-03-18	N/A
Password File	Sensitive data exposure	2026-03-18	SHA256

Capstone Mapping (Full Cycle) :

Phase	Activity
Recon	Asset Directory
Scanning	Nmap & Nikto
Exploitation	Netcat shell
Post – Exploitation	Data access
Reporting	This document

Remediation :

- Disable Telnet.
- Upgrade Apache.
- Patch vsftpd.
- Enable security headers.
- Restrict SMB access.
- Implement firewall rules.

Non – Technical Summary :

- The assessment revealed critical security weaknesses in the system, including outdated software, exposed services, and insecure configurations.
- These vulnerabilities allowed full administrative access to the system, demonstrating a high risk of compromise.
- Immediate remediation is required, including updating software, disabling insecure services, and applying proper security controls.
- Strengthening these areas will significantly improve the system's overall security posture and reduce the likelihood of cyberattacks.

Key Learnings :

- Scanning reveals attack surface.
- Exploitation validates vulnerabilities.
- Misconfigurations lead to compromise.

- CVSS helps prioritize risks.
- Post-exploitation proves impact.
- Importance of validating vulnerabilities to avoid false positives.
- Understanding how multiple vulnerabilities can be chained for deeper exploitation.
- Hands-on practice improves practical penetration testing skills significantly.

Challenges :

- OpenVAS setup issues.
- Resource limitations.
- Tool performance issues.
- Filtering false positives.
- Correlating scan results with exploitability.

Conclusion :

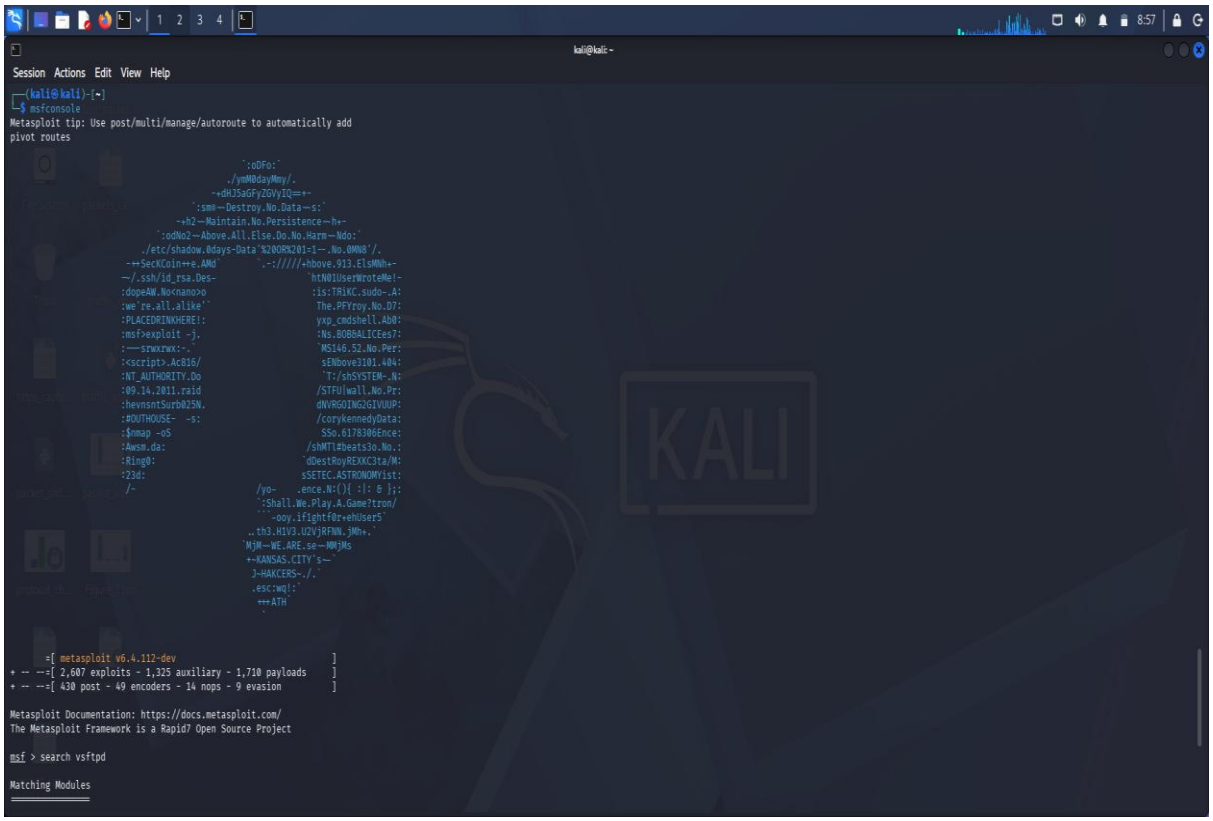
- The VAPT assessment successfully identified and exploited multiple vulnerabilities within the target system.
- The results demonstrate a critical security posture requiring immediate remediation.
- Implementing recommended measures will significantly enhance system security.

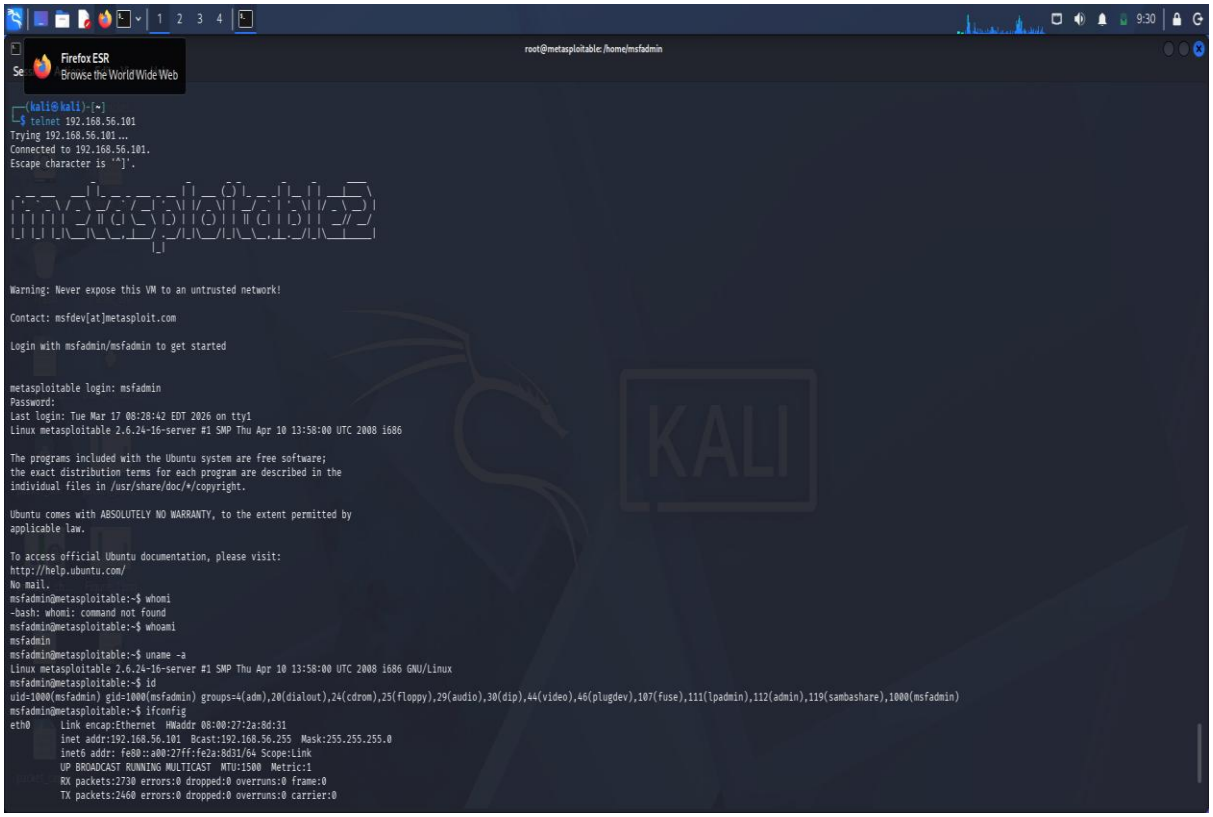
Snapshots :

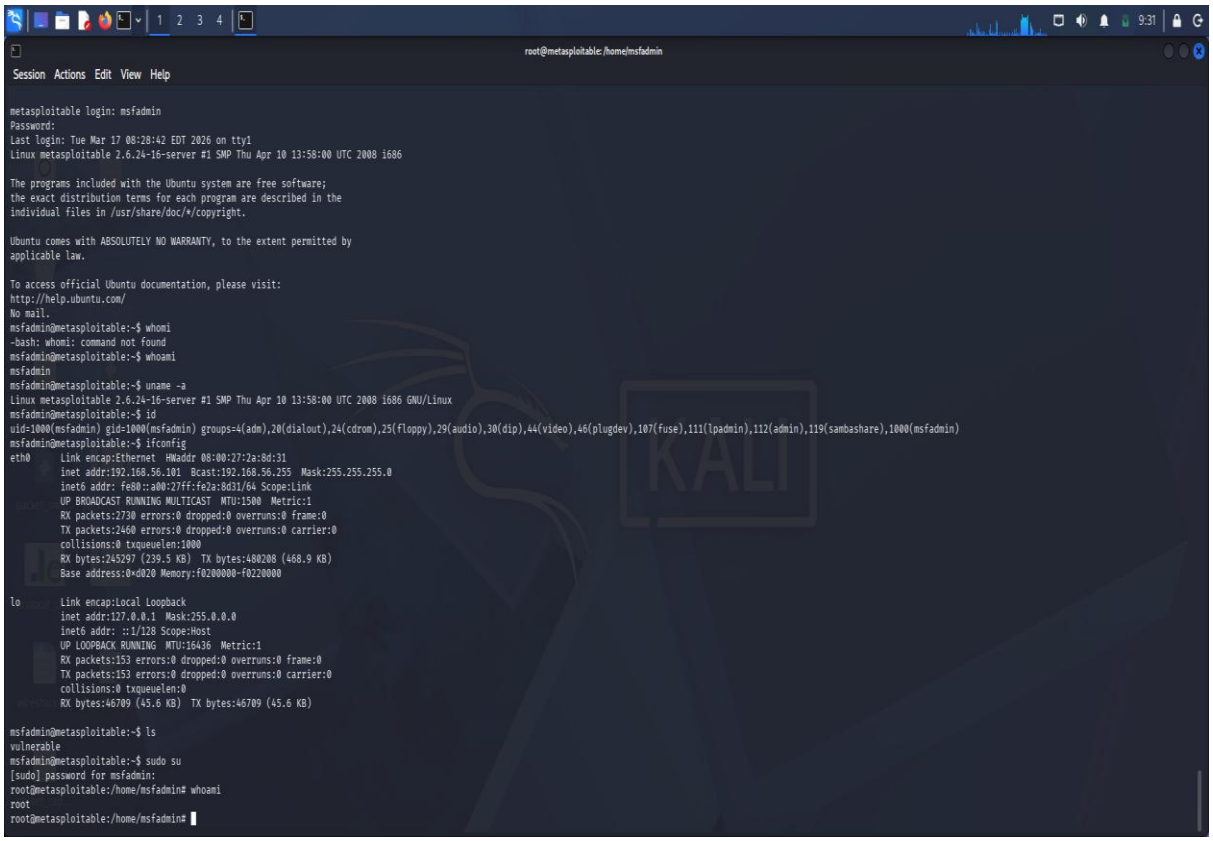
```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -sC 192.168.56.101
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-17 08:34 -0400
Nmap scan report for 192.168.56.101
Host is up (0.048s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.107
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_    SSL2_RC4_128_EXPORT40_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-03-17T12:29:35+00:00; -5m06s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
```

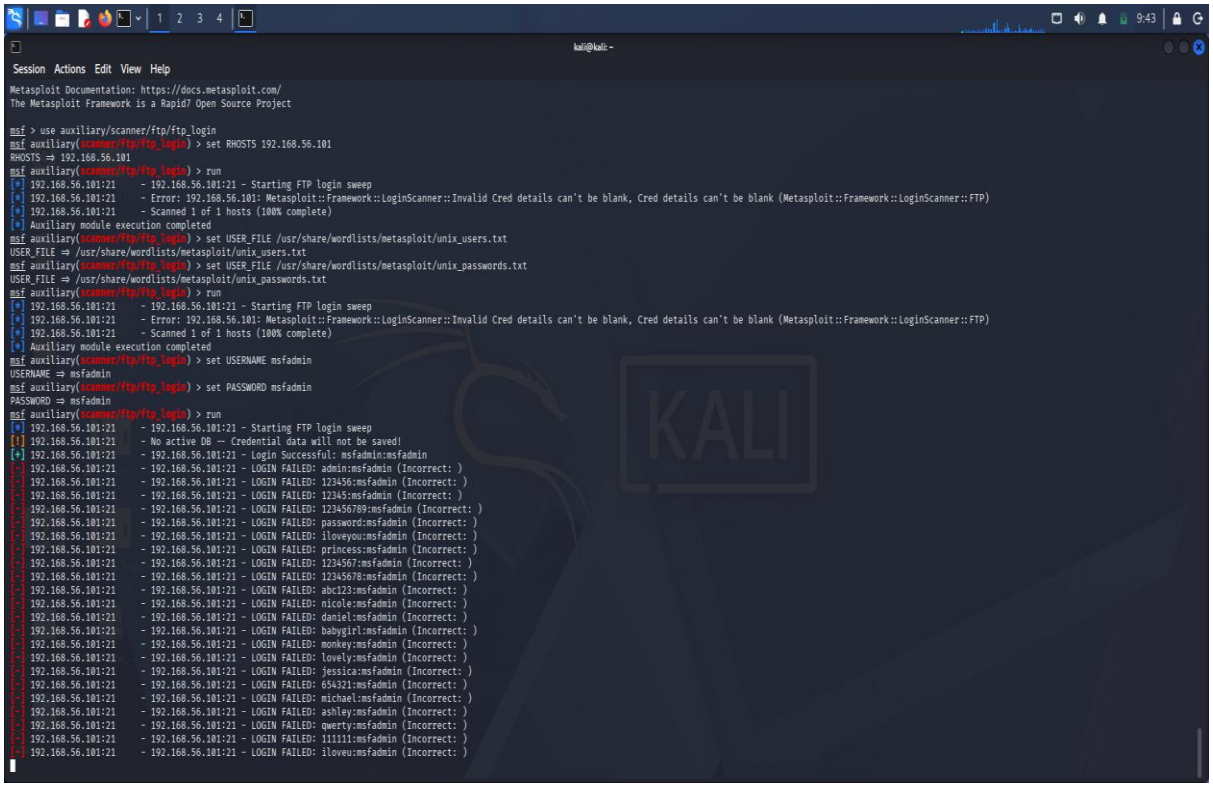
```
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      36544/tcp   mountd
|   100005  1,2,3      58808/udp   mountd
|   100021  1,3,4      35546/udp   nlockmgr
|   100021  1,3,4      39253/tcp   nlockmgr
|   100024  1          40857/udp   status
|_  100024  1          52708/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 8
|   Capabilities flags: 43564
|   Some Capabilities: ConnectWithDatabase, SupportsTransactions, Speaks41ProtocolNew, Support41Auth, LongColumnFlag, SwitchToSSLAfterHandshake, SupportsCompression
|   Status: Autocommit
|_  Salt: FWcmy:Sp\Z16hZk-9vj/
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-03-17T12:29:35+00:00; -5m07s from scanner time.
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-favicon: Apache Tomcat
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:2A:8D:31 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
```

(Nmap Scan Results)

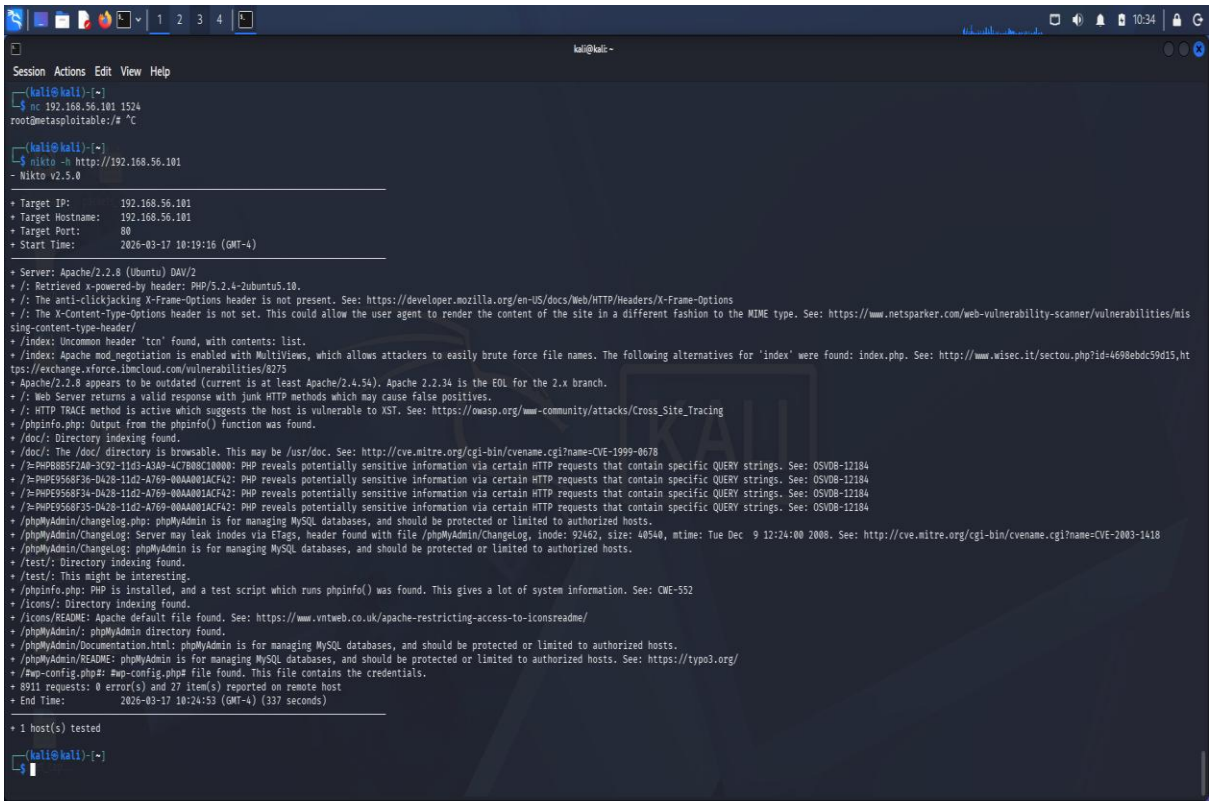



root@metasploitable: /home/msfadmin
Firefox ESR
Browse the World Wide Web
(kali㉿kali)-[~]
$ telnet 192.168.56.101
Trying 192.168.56.101 ...
Connected to 192.168.56.101.
Escape character is '^]'.
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started
metasploitable login: msfadmin
Password:
Last login: Tue Mar 17 08:28:42 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whomi
-bash: whomi: command not found
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ ifconfig
eth0 Link encap:Ethernet HWaddr 08:00:27:2a:8d:31
inet addr:192.168.56.101 Bcast:192.168.56.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:fe2a:8d31/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:2730 errors:0 dropped:0 overruns:0 frame:0
TX packets:2460 errors:0 dropped:0 overruns:0 carrier:0


root@metasploitable: /home/msfadmin
Session Actions Edit View Help
metasploitable login: msfadmin
Password:
Last login: Tue Mar 17 08:28:42 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whomi
-bash: whomi: command not found
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admin),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:~$ ifconfig
eth0 Link encap:Ethernet HWaddr 08:00:27:2a:8d:31
inet addr:192.168.56.101 Bcast:192.168.56.255 Mask:255.255.255.0
inet6 addr: fe80::a00:27ff:fe2a:8d31/64 Scope:Link
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
RX packets:2730 errors:0 dropped:0 overruns:0 frame:0
TX packets:2460 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:1000
RX bytes:245297 (239.5 KB) TX bytes:480208 (468.9 KB)
Base address:0×d020 Memory:f0200000-f0220000
lo Link encap:Local Loopback
inet addr:127.0.0.1 Mask:255.0.0.0
inet6 addr: ::1/128 Scope:Host
UP LOOPBACK RUNNING MTU:16436 Metric:1
RX packets:153 errors:0 dropped:0 overruns:0 frame:0
TX packets:153 errors:0 dropped:0 overruns:0 carrier:0
collisions:0 txqueuelen:0
RX bytes:46709 (45.6 KB) TX bytes:46709 (45.6 KB)
msfadmin@metasploitable:~$ ls
vulnerable
msfadmin@metasploitable:~$ sudo su
[sudo] password for msfadmin:
root@metasploitable:/home/msfadmin# whoami
root
root@metasploitable:/home/msfadmin#



(Exploitation using Metasploitable 2 Framework)



(Nikto Results & Root Shell Access Exploitation & Detection)